

Compliance, Governance & Final Decision Framework

NIST SP 800-53 is the US federal standard for security controls and is widely adopted as the foundational control framework for financial services. The authorization architecture directly implements the Access Control (AC) and Audit and Accountability (AU) control families.

NIST Access Control Family (AC) · AI Act · ISO 27001 · Case Studies · Migration

Control ID	Control Name	Architecture Implementation	Evidence Artifact
AC-2	Account Management	Cedar entity store tracks all principals (users and agents). SCIM provisioning creates and removes principals automatically.	SCIM sync logs, Cedar entity audit, deprovisioning CloudTrail events
AC-3	Access Enforcement	Cedar PDP enforces access control decisions for every request. PEP at API Gateway and middleware. Default deny posture.	AVP IsAuthorized CloudTrail logs, Lambda Authorizer execution logs
AC-4	Information Flow Enforcement	Cedar output classification policies control what data can flow to which principals. DLP scan on all outputs.	Cedar output policy decisions, Bedrock Guardrails logs, Macie findings
AC-5	Separation of Duties	Policy authors cannot deploy without security review. Agents cannot accumulate permissions across steps. Human approval for sensitive actions.	GitHub PR approvals, Step Functions approval records, Cedar forbid policies
AC-6	Least Privilege	Agents receive minimum scope at delegation time. Capabilities scoped to specific task type. Tool access restricted by agent type.	Delegation token scope claims, Cedar agent type policies, tool access logs
AC-7	Unsuccessful Logon Attempts	JWT replay detection blocks replayed tokens. Risk score increases on repeated denials. GuardDuty monitors for brute force.	ElastiCache jti blacklist, GuardDuty findings, CloudWatch denial metrics
AC-17	Remote Access	VPN zone check in Cedar context. Restricted tool access from non-corporate networks. MFA re-authentication for remote sessions.	Network zone claim in canonical claims, Cedar network zone policies
AC-23	Data Mining Protection	RAG pre-retrieval filter limits bulk document access. Cedar policy restricts query volume. Bulk export requires explicit capability.	OpenSearch filter logs, Cedar bulk export policies, export audit records

1.2 Audit and Accountability Family (AU)

Control ID	Control Name	Architecture Implementation	Evidence Artifact
AU-2	Event Logging	Every Cedar IsAuthorized call logged to CloudTrail. Agent tool invocations logged at MCP PEP. RAG access logged per chunk.	CloudTrail event history, MCP PEP logs, RAG access DynamoDB records
AU-3	Content of Audit Records	Audit schema captures: timestamp, principal, action, resource, decision, policy ID, context hash, latency, obligation.	Audit record schema (DynamoDB), CloudTrail event detail format

Control ID	Control Name	Architecture Implementation	Evidence Artifact
AU-6	Audit Record Review	Automated anomaly detection via CloudWatch Metrics Insights. Monthly access review reports. SIEM integration for continuous monitoring.	CloudWatch alarms, access review reports, SIEM dashboard
AU-9	Protection of Audit Information	S3 Object Lock (WORM) for CloudTrail logs. Separate security account for log storage. KMS encryption. Log integrity validation.	S3 Object Lock config, cross-account log bucket policy, CloudTrail validation status
AU-11	Audit Record Retention	CloudTrail logs retained 7 years (regulatory minimum). DynamoDB audit table: 90 days hot, 7 years in S3 Glacier.	S3 lifecycle policy, DynamoDB TTL configuration, Glacier vault
AU-12	Audit Record Generation	Lambda Authorizer generates audit record for every authorization decision including denials. Async write to DynamoDB + CloudWatch.	Lambda Authorizer audit code, CloudWatch log groups, DynamoDB write throughput

2. NIST AI Risk Management Framework (AI RMF)

The NIST AI RMF (published January 2023) is the emerging standard for managing risk in AI systems. The authorization architecture implements controls across all four core functions: GOVERN, MAP, MEASURE, and MANAGE.

AI RMF Function	Sub-Category	Authorization Architecture Control	Evidence
GOVERN 1.1	AI risk governance policies	Policy-as-code with PR review and approval gates ensures all AI agent behaviors are governed by written, auditable policies.	GitHub policy repository, PR approval records, Cedar policy store
GOVERN 1.2	Accountability structures	Cedar decision logs attribute every action to a principal and a policy. Human approval obligation creates clear accountability for high-risk actions.	CloudTrail AVP events, Step Functions approval records
GOVERN 4.1	Organizational teams	Policy Review Board (security, privacy, compliance, IAM) reviews all policy changes. Delegated administration scopes are defined and documented.	Policy Review Board charter, PAP governance policy
MAP 2.3	AI system categorization	Agent types are categorized (customer service, payment, compliance) with explicit permitted tool sets. Capability taxonomy documents agent risk levels.	Agent type taxonomy table, Cedar agent type policies
MAP 3.5	Risk identification	STRIDE threat model applied to authorization layer. Risk scoring integrates GuardDuty and Fraud Detector signals.	STRIDE threat model doc, risk score computation code
MEASURE 2.6	Policy compliance metrics	Shadow evaluation measures policy decision accuracy before production. CloudWatch tracks allow/deny rates, policy drift, and latency.	Shadow eval comparison reports, CloudWatch dashboards
MEASURE 2.9	AI performance monitoring	Agent confidence score impacts authorization. Low-confidence agent actions require human approval. Audit trail captures confidence at decision time.	Cedar confidence score policy, Step Functions HITL records
MANAGE 1.3	Incident response	Emergency policy rollback procedure (< 5 min). Automated policy drift detection. Break-glass procedure for production policy access.	Rollback runbook, Config rule alarm, break-glass IAM policy
MANAGE 2.4	Decommissioning	Agent deprovisioning removes delegation scope immediately via SCIM sync. Cedar entities deactivated in AVP. Audit trail preserved.	SCIM deprovisioning logs, Cedar entity deactivation, retention policy

3. PCI DSS v4.0 Control Implementation

PCI DSS v4.0 (effective March 2024) introduces enhanced requirements for access control, multi-factor authentication, and targeted risk analysis. The authorization architecture implements the following PCI DSS requirements:

Requirement	Description	Implementation	Testing Evidence
Req 7.2	Access control system	Cedar AVP is the centralized access control system for all cardholder data environments. Default deny; explicit permit only.	Cedar policy store configuration, AVP IsAuthorized call logs
Req 7.3.1	All access to system components is by individual	Each agent has a unique identity (not shared). User delegation preserves individual identity in act claim.	Delegation token claims, agent identity registration records
Req 8.3.6	MFA for all personnel	Cedar policy requires mfaVerified=true for all payment tool access. MFA method validated (phishing-resistant required for high-value).	Cedar MFA policies, mfaMethod claim in canonical claims, denial logs for non-MFA
Req 8.3.9	User passwords changed every 90 days	Entra ID password policy enforced upstream. Authorization layer checks session age; re-auth required > 1 hour.	Entra ID password policy screenshot, Cedar session age policy
Req 10.2	Audit logs capture required events	Audit record captures: user, date/time, action, affected data system, type of activity, originating location.	Audit record schema comparison with Req 10.2 checklist
Req 10.3	Protect audit logs from destruction	S3 Object Lock (compliance mode) on CloudTrail log bucket. Cross-account storage in Security account. KMS encryption.	S3 Object Lock policy, S3 bucket policy, KMS key policy
Req 10.4	Review audit logs daily	CloudWatch alarms for anomalous authorization patterns (spike in denials, off-hours access, cross-tenant attempts). PagerDuty integration.	CloudWatch alarm configurations, PagerDuty escalation policy
Req 12.6	Security awareness training	Policy Review Board includes training requirement. Cedar policies encode business rules that developers must understand.	Training records, Policy Review Board attendance log

4. DORA and EU AI Act Compliance

4.1 DORA (Digital Operational Resilience Act)

DORA (effective January 2025) mandates ICT risk management and operational resilience for financial entities in the EU. The authorization architecture addresses DORA's most critical ICT risk requirements:

DORA Article	Requirement	Implementation
Art. 5 — ICT Risk Management	Identify, classify, and manage ICT risks on a continuous basis	STRIDE threat model for authorization layer. GuardDuty continuous threat detection. Risk score integration. Quarterly threat model review.
Art. 9 — Protection & Prevention	Protect information assets against data leakage	Cedar output classification policies. DLP scan on all agent outputs. Tenant isolation. Data residency enforcement via geography claims.
Art. 10 — Detection	Detect anomalous activities and ICT-related incidents	CloudWatch anomaly detection on authorization decisions. GuardDuty findings routed to Security Hub. SIEM integration for real-time alerting.
Art. 11 — Response & Recovery	Respond to and recover from ICT-related incidents	Emergency policy rollback procedure (< 5 min). Circuit breakers in PEP for PDP failures. Playbook for authorization-related incidents.
Art. 12 — Backup & Recovery	Back up systems and data and restore them	AVP policy store backed up via GitOps (Git is the source of truth). ElastiCache Redis multi-AZ. DynamoDB point-in-time recovery enabled.
Art. 17 — ICT-related incidents	Classify and report ICT incidents to regulators	Authorization-related security incidents classified by severity. CloudTrail evidence package auto-generated for regulatory reporting within 72 hours.
Art. 28 — Third-party risk	Manage ICT third-party service provider risks	AWS (AVP, Bedrock, ECS) treated as critical ICT third party. Contract includes exit strategy. Policies stored in Git (not vendor-locked in AVP only).

4.2 EU AI Act Compliance

The EU AI Act (effective August 2026 for high-risk AI systems) establishes requirements for AI systems deployed in regulated sectors including financial services. AI agents that make or influence credit decisions, fraud detection, or financial advice are likely classified as high-risk AI systems:

EU AI Act Article	Requirement	Authorization Architecture Control
Art. 9 — Risk Management	Establish, implement, and maintain a risk management system throughout the AI system's lifecycle	Cedar policy lifecycle management (PAP). STRIDE threat model. Risk scoring integration. Quarterly policy review cadence.
Art. 10 — Data Governance	Data used must be relevant, representative, and free from errors	RAG authorization prevents unauthorized/irrelevant data injection into agent context. Document classification controls data quality.
Art. 13 — Transparency	High-risk AI systems must be transparent and provide information to deployers	Authorization decision logs capture policy IDs that determined the decision. Human-readable policy descriptions required in Cedar policy metadata.

EU AI Act Article	Requirement	Authorization Architecture Control
Art. 14 — Human Oversight	Enable human oversight, including ability to intervene, halt, or override the AI system	Step Functions human approval workflow. Emergency policy rollback can halt all agent tool access in < 5 minutes. Human override of Cedar deny decisions via approval workflow.
Art. 17 — Quality Management	Implement a quality management system with post-market monitoring	Shadow evaluation detects policy regression before production. CloudWatch monitors authorization decision quality (unexpected allow rate changes). Automated regression tests.
Art. 26 — Obligations for Deployers	Deployers must ensure human oversight and monitor AI system operation	Compliance dashboard showing authorization decision metrics. Automated access review reports. Anomaly alerts to designated compliance officer.

5. Complete Anti-Pattern Catalogue with Remediation

The following is an exhaustive catalogue of authorization anti-patterns observed in enterprise AI deployments, with specific remediation guidance for each:

[CRITICAL] AP-01: Authorization Logic in Business Code

Anti-Pattern: `if user.role == 'admin' or user.group in ['Finance_Approvers', 'Payments_Admins']:`
`execute_payment()`

Remediation: Extract ALL authorization logic to Cedar/OPA. Business service calls PEP, receives Allow/Deny, and ONLY executes on Allow. Zero authorization logic in service code.

[HIGH] AP-02: Direct Identity Store References in Policy

Anti-Pattern: Cedar policy: `when principal.groups contains 'Payments_Admins_GUID_abc123'`

Remediation: Map Entra groups to canonical capabilities in the normalization layer. Cedar policies reference only capabilities: `when principal.capabilities contains 'can_approve_payment'`

[CRITICAL] AP-03: No Default Deny

Anti-Pattern: Authorization returns Allow unless an explicit Deny rule is found (deny-unless-permitted model)

Remediation: Cedar's default is deny — no policy needed. OPA: `default allow := false`. API Gateway Lambda Authorizer: `throw Exception('Unauthorized')` on any non-Allow path.

[HIGH] AP-04: Overly Large JWTs

Anti-Pattern: Encoding 500+ group GUIDs in the JWT, resulting in 8KB tokens that exceed HTTP header limits

Remediation: Use reference token pattern. Issue opaque token to client; PIP Lambda introspects for full attributes. Or use SCIM to pre-populate DynamoDB; JWT carries only user ID.

[HIGH] AP-05: No Policy Versioning

Anti-Pattern: Policies edited directly in AVP console without version control or change history

Remediation: All policies managed in Git as code. AVP is populated only via CI/CD pipeline. Git commit history provides version control. Rollback = `git revert` + pipeline.

[CRITICAL] AP-06: Policy Evaluation After Execution

Anti-Pattern: Agent executes tool action, then logs the decision. If unauthorized, tries to 'undo' the action.

Remediation: Authorization is ALWAYS evaluated BEFORE execution. Cedar `IsAuthorized` returns before any business logic runs. No exceptions.

[CRITICAL] AP-07: Missing Decision Logging

Anti-Pattern: Authorization decisions are made but not logged. No record of what was permitted or denied.

Remediation: Every Cedar IsAuthorized call produces an audit record (CloudTrail + DynamoDB). Both Allow and Deny decisions are logged with full context.

[HIGH] AP-08: Shared Agent Identity

Anti-Pattern: All agents run under a single shared identity (e.g., 'agent-service') making individual accountability impossible

Remediation: Each agent instance has a unique identity. Agent ID is composed of: agent type + task ID + timestamp. Delegation carries individual user identity in act claim.

[CRITICAL] AP-09: No Tool Authorization

Anti-Pattern: Agent selects and invokes tools based on LLM reasoning with no policy enforcement. Any tool can be called by any agent.

Remediation: Every tool invocation passes through Cedar authorization. Tool access is restricted by agent type, user capability, context, and tool-specific policies.

[HIGH] AP-10: Transitive Trust Between Agents

Anti-Pattern: Orchestrator agent vouches for sub-agent permissions. Sub-agents inherit orchestrator's full permission set.

Remediation: Each agent boundary triggers independent Cedar evaluation. Sub-agent scope = intersection of orchestrator scope and sub-agent permitted scope. Never union.

[HIGH] AP-11: Single-Environment Policy Store

Anti-Pattern: Development, staging, and production all use the same Cedar policy store. Dev policy changes affect production.

Remediation: Separate AVP policy stores per environment. CI/CD pipeline deploys environment-specific. Production store protected by SCPs and IAM condition requiring pipeline role.

[CRITICAL] AP-12: No Tenant Isolation in RAG

Anti-Pattern: Vector similarity search returns results from all tenants. Tenant filtering is applied only at the application layer (can be bypassed).

Remediation: Tenant filter applied as mandatory metadata filter in the vector query (pre-retrieval). Post-retrieval Cedar per-chunk authorization. Tenant isolation is defense-in-depth.

[MEDIUM] AP-13: Permissive Cache TTL

Anti-Pattern: Authorization decisions cached for 24 hours. Policy changes are not reflected until cache expires.

Remediation: Cache TTL aligned with JWT expiry (max 1 hour for claims cache). Decision cache (API GW) set to 300s. Cache invalidated immediately on policy change via EventBridge.

[HIGH] AP-14: No Shadow Evaluation Before Enforcement

Anti-Pattern: New authorization policies deployed directly to production without comparing decisions against existing system.

Remediation: Mandatory shadow evaluation phase achieves >99.9% decision parity before any enforcement. Shadow mode runs for minimum 1 hour of production traffic.

[CRITICAL] AP-15: Authorization Bypass via Direct AWS API Calls

Anti-Pattern: Agent calls S3, DynamoDB, or other AWS services directly via IAM role, bypassing Cedar authorization entirely.

Remediation: IAM task roles for agents are minimally scoped (bedrock:InvokeModel only). All data access goes through authorized service APIs. S3 bucket policies deny direct agent access.

6. The Definitive Decision Framework

This section provides the final, authoritative guidance on authorization engine selection. It synthesizes all research across this series into a decision framework supported by industry evidence and implementation patterns.

6.1 When Cedar (AVP) is the Clear Choice

- **AWS-native deployment:** No other engine integrates as deeply with API Gateway, Lambda, Bedrock, and CloudTrail. AVP is a managed service with no operational burden.
- **Type-safe business authorization:** Cedar's schema validation and formal verification make it the only engine that can be submitted as a formally correct authorization system to regulators.
- **Banking/regulated authorization:** Cedar's native CloudTrail integration satisfies PCI DSS Req 10 (audit logging) with zero additional configuration.
- **Agent and tool permissions:** Cedar's entity model naturally represents agent types, tool capabilities, and delegation relationships in a single coherent schema.
- **Multi-tenant SaaS with policy delegation:** Cedar templates and entity hierarchies are specifically designed for multi-tenant policy management.
- **Need for fast time-to-value:** Cedar policies read like business rules. Security team can write and review policies without deep systems programming knowledge.

6.2 When OPA/Rego is the Clear Choice

- **Kubernetes and container security:** OPA Gatekeeper is the CNCF-blessed standard for K8s admission control. No other engine has this level of ecosystem support for K8s.
- **Infrastructure-as-Code policy gates:** Conftest + Rego is the standard for Terraform and Helm chart policy validation in CI/CD pipelines.
- **Multi-cloud or cloud-agnostic requirements:** OPA runs identically on AWS, Azure, GCP, and on-premises. Cedar is AWS-specific.
- **Existing OPA investment:** If the organization already runs Styra DAS or OPA sidecars, adding Cedar creates two policy ecosystems to maintain for application authorization.
- **Service mesh policy:** OPA integrates natively with Envoy, Istio, and Linkerd for L7 service mesh policy. Cedar has no service mesh integrations.
- **Edge/WASM enforcement:** Only OPA can compile policies to WebAssembly for enforcement at CDN edge locations.

6.3 When the Hybrid Architecture Wins

The hybrid architecture — Cedar for application/agent authorization, OPA for infrastructure policy — is the strongest choice for enterprise deployments where:

- The organization runs EKS (Kubernetes) AND has application authorization requirements
- Terraform IaC policy gates are required in addition to runtime authorization
- A service mesh (Istio/Envoy) provides East-West traffic policy enforcement
- The organization is large enough to justify the operational investment in two policy engines
- Regulatory requirements mandate both infrastructure-level and application-level authorization evidence
- Development teams have Rego expertise that would be lost by migrating entirely to Cedar

✓ BEST PRACTICE

Final Verdict for the Described Environment: The enterprise described in this research (AWS, Entra ID, EKS+ECS, Bedrock AgentCore, banking regulation, multi-tenant, Agentic AI) should implement the HYBRID architecture: Amazon Verified Permissions (Cedar) for all user, agent, tool, RAG, and memory authorization decisions — paired with OPA/Gatekeeper on EKS for Kubernetes admission control, Conftest for Terraform policy gates, and OPA+Envoy for service mesh L7 policy. The shared claims normalization service provides canonical identity context to both engines. This is not a compromise — it is intentional specialization that delivers the strongest security posture, the clearest compliance evidence, and the most maintainable long-term authorization architecture.

7. Industry Implementation Evidence

Capital One + AWS Cedar

Capital One's public re:Invent presentations (2022-2024) describe their use of Amazon Verified Permissions as the authorization backbone for their cloud-native banking platform. They specifically cite the benefit of separating Cedar's formal verification from application code. Their Lambda Authorizer pattern is now documented as an AWS reference architecture. Key metric: <3ms P99 authorization latency across all banking APIs serving millions of customer transactions daily.

Netflix + OPA

Netflix's engineering blog posts (2021-2024) describe OPA as their universal policy engine for Kubernetes (hundreds of clusters), Spinnaker deployment pipelines, and internal service authorization. Netflix explicitly chose OPA over XACML for its developer ergonomics and Rego's expressiveness. They run OPA as a sidecar in every service, with centrally managed policy bundles from S3. Key metric: <1ms sidecar evaluation; policy bundles updated every 30 seconds globally.

Styra + Enterprise OPA (Intuit, Atlassian)

Styra's published case studies (available at styra.com) document Intuit managing OPA policies across 300+ microservices using Styra DAS, and Atlassian using OPA for Kubernetes admission control across their multi-cloud infrastructure. Both organizations cite the GitOps workflow and centralized policy management as the primary enterprise value over ad-hoc OPA deployments.

Goldman Sachs — Fine-Grained Access Control

Goldman Sachs's engineering blog and conference presentations describe their FGAC (Fine-Grained Access Control) system for trading platform authorization. Their system evaluates authorization at the instrument level (can trader X see the price of bond Y?) using an attribute-based model similar to Cedar. They process >100 million authorization decisions per day with <2ms P99 latency. Key design: attribute resolution from multiple source-of-truth systems (trader books, risk limits) mirrors the PIP pattern described in this architecture.

Auth0 (Okta) + Fine-Grained Authorization

Auth0's FGA product (now Okta FGA, based on OpenFGA/Zanzibar) serves as evidence for the ReBAC model at enterprise scale. Okta's published benchmarks show >100,000 authorization checks per second with consistent sub-5ms latency. Their use case (multi-tenant SaaS) demonstrates that relationship-based authorization (as a complement to Cedar in a hybrid model) is production-proven at significant scale.

AWS Internal + Cedar Formal Verification

AWS Research's published papers on Cedar describe its use internally at Amazon for authorizing access to AWS services themselves. The Lean-based formal verification proofs are available on GitHub ([cedar-policy/cedar-spec](https://github.com/cedar-policy/cedar-spec)). AWS's own commitment to Cedar for internal authorization is the strongest endorsement of its production readiness for regulated enterprise workloads.